Monthly Intelligence Dispatch

September 2019

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specialises in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Group-IB has tracked a new campaign of the Android Trojan FANTA, attacking customers of 70 banks, payment systems and web wallets in Russia and the Post-Soviet countries. The Trojan is targeting users of the online services Avito, AliExpress, Yula, Pandao, Aviasales, Booking, and Trivago.
- Silence has activated a new C&C server and is conducting attacks with the assistance of the hacker group TA505.
- Group-IB has discovered compromised cards of Singapore bank customers; the attackers may have stolen this data from online stores using JS-sniffers.
- Lazarus is using the Dtrack malware to attack financial institutions in India.
- Group-IB specialists tracked attacks involving JS-backdoor aka More_Eggs from July to August 2019. Either the Cobalt group or other APTs may have been behind the attacks.

FANTA

Group-IB detected a new campaign of the Android Trojan FANTA attacking customers of 70 banks, payment systems and web wallets in Russia and the Post-Soviet countries. The Trojan is targeting users of the online services Avito, AliExpress, Yula, Pandao, Aviasales, Booking, Trivago, as well as carsharing services, taxis, etc. Most of the infected devices are located in Russia, followed by Ukraine, Kazakhstan, and Belarus. Since early 2019, the potential damage from FANTA in Russia has amounted to at least 35 million rubles ($540,000).

FANTA belongs to the Flexnet family, which has been known since 2015 and has been studied thoroughly. The Trojan and its infrastructure are constantly evolving: attackers are developing new effective distribution schemes; new features have been added that help steal money from infected devices and bypass security features.

Group-IB Threat Intelligence specialists determined that some phishing pages involved in the campaign were disguised as the ad placement service Avito.ru. In addition to Avito, FANTA developers are targeting users of 30 online services, including AliExpress, Yula, Pandao, Aviasales, Booking, Trivago, as well as carsharing and taxi services.

FANTA identifies running applications on the infected device. Once the target application is launched, the Trojan displays a phishing window on top of other app windows, which is a form for entering bank card details. The user must enter the following data: card number, card expiration date, CVV, card holder name (not for all banks). Analysis of the Trojan showed that in addition to demonstrating custom phishing pages, Fanta also reads notification messages from 70 banking applications, instant payment systems and e-wallets.

Major events: espionage, sabotage, leaks

0-day for iOS

Google's Threat Analysis Group (TAG) has discovered at least **11** hacked Uyghur sites that have been used to hack and spy on iPhone users since 2017. Simply visiting the hacked site was enough for the exploit server to attack a device. Hackers got full access to the infected device with root privileges, including the ability to read any data and install any applications. Criminals deployed a monitoring implant, capable of copying user files and tracking geolocation. In particular, exploit chains for iOS were discovered, using a total of fourteen vulnerabilities in the Apple iOS mobile operating system, covering almost every version from iOS 10 through to the latest version of iOS 12. Android and Microsoft Windows could have also been victims of the malicious campaign. In the end, the FBI had to ask Google to remove sites from search results to prevent new infections.

Guotai Junan Securities

In August 2019, a user nicknamed VincentVega published an offer to purchase access to the corporate network of an unidentified Chinese company. The seller indicated that they had two remote accesses to the company's corporate network containing **more than 20,000 local IP addresses**. The seller also gained access to 865 devices via **RDP**—the Remote Desktop Protocol—using brute force attacks. 500 devices had administrative rights. The announcement did not contain the name of the affected company. Group-IB specialists contacted the seller and found out that the company in question was Guotai Junan Securities, located in Hong Kong.

APT28/
APT29

On September 24, 2019, **Checkpoint**, together with another Israeli company **Intezer**, released a report in which they presented an interactive map of connections between Russian-speaking state-sponsored groups, which are allegedly linked to Russia's security services. Intezer has developed a machine learning algorithm that is designed to identify relationships between programs (i.e. binary files) without their source codes. Analysis revealed more than 22,000 connections between the samples, in addition to 3.85 million non-unique pieces of code that were shared. As a result, experts came to the conclusion that Russian actors rarely shared code with each other. The report did not bring completely new information, because connections between the attacks had been previously noted by other experts. The research, however, makes it possible to quickly identify the links between the tools of state-sponsored hacker groups and understand the basis of such connections.

Cobalt Dickens

Cyber experts at Secureworks discovered the attacks, which they believe stem from the Cobalt Dickens group operating out of Iran. More than 60 universities in the United States, Canada, Britain, Switzerland and Australia have been targeted in the global phishing campaign. The campaign involved creating fake websites that resembled login pages for each university. Victims were tricked into visiting these websites using phishing emails containing relevant links. In the spring of 2018, U.S. authorities indicted in absentia nine Iranian citizens who, according to them, were members of a “government” hacking group affiliated with the Mabna Institute, a company created in 2013 for attacks on universities, scientific journals, technology companies and government organizations. It was reported that over the years of its existence, the group stole more than 32 terabytes of academic and research data. According to investigators, hackers targeted 100,000 accounts of professors and employees of educational institutions around the world and successfully cracked about 8,000 of them.

Lazarus, Bluenoroff и Andarial	The U.S. Department of the Treasury imposed sanctions on three North-Korean APT groups—Lazarus, Bluenoroff, and Andarial. The groups are known for conducting a series of attacks against critical U.S. infrastructure and stealing hundreds of millions of dollars from financial institutions around the world. U.S. authorities claim that the stolen funds were used by the North Korean government to support illicit weapon and missile programs. The sanctions imposed by the Office of Foreign Assets Control (OFAC) are designed to block any assets of financial institutions that knowingly facilitate transactions or provide other services to these APT groups.
Lazarus	Kaspersky Lab specialists detected a previously unknown spyware created by the North Korean group Lazarus in the networks of Indian financial organizations and research centers. The most recent activity of the DTrack banking Trojan was observed in early September 2019. Analysis showed that the malware was designed to be planted on the victim's ATMs, where it could read and store the data of cards that were inserted into the machines. Researchers identified more than 180 new samples of espionage tools, later called Dtrack.

Silence

In September 2019, Group-IB experts detected that Silence tools were being uploaded to VirusTotal. Unfortunately, all samples had fake dates of resource compilation, which prevented specialists from establishing the relevance of programs. However, Group-IB experts believe that one of the servers has been activated recently and is being actively used by the group to conduct attacks on banks. As part of incident response activities in one of the European banks this summer, Group-IB specialists detected that Silence's main Trojan was loaded into the system using Servhelper backdoor that belongs to the TA505 group. This once again confirms that Silence cooperates with TA505 and uses their infrastructure and/or purchases downloads for attacks on banks. In August, Group-IB published the technical report "Silence 2.0: Going Global" that described the attacks of the Russian-speaking group Silence. The confirmed damage from Silence's operations from June 2016 to June 2019 was estimated at USD 4.2 mln. Group-IB experts have been continuously monitoring Silence activity since 2016. Group-IB's Threat Intelligence team has detected at least 16 new campaigns targeting banks launched by Silence. In general, according to Group-IB, in 2019, the geography of Silence attacks became the most extensive for the entire existence of the group: Silence infected workstations in more than 30 countries across Europe, Asia, and the Post-Soviet region. The gang's recent confirmed successful attacks, known to Group-IB specialists, were detected in Chile, Bulgaria and Ghana (July), Russia (several banks, June), Kyrgyzstan (May), Bangladesh (May, Dutch-Bangla Bank), Russia (Omsk IT Bank, February), and India (January). The total confirmed amount of funds stolen by Silence has increased fivefold since the publication of Group-IB's original report, and is estimated at USD 4.2 mln now.

"Cobalt"

Group-IB specialists tracked attacks involving JS-backdoor aka More_Eggs in July-August 2019. Either Cobalt group or other APTs may have been behind the attacks. The Trojan was offered for sale on underground forums. Files were uploaded to VirusTotal via web interface from Poland, the UK, or the USA. Through analysis of the underground forums, Group-IB specialists found the author of More_eggs and established that this JS-backdoor was put on sale at least in July 2018. The author is a user nicknamed badbullzvenom. The seller mentioned their connection with the criminal group Cobalt several times. According to badbullzvenom, Cobalt uses their loader and they are engaged in its support. The seller did not provide any evidence of this.

Major events: attacks on banks and their customers

Java Script-sniffers	Group-IB discovered compromised cards related to Singaporean banks. A database called “31.03-SG_MIX_SNIFF” appeared on an underground carding forum on April 1, 2019. It contained data of **1,726** compromised cards issued by Singapore banks. In just eight months of 2019, Group-IB experts discovered data of 26,210 local bank cards in underground card shops. Their total market value is estimated at almost $1.8 million. The risk is that the data published contains all information required for online purchases, including CVVs, card numbers, and expiration dates. Group-IB experts believe that cards may have been compromised in online stores as a result of attacks involving JavaScript-sniffers. Despite the fact that online sellers are responsible for ensuring the safety of their customers' data, many large-scale data leaks (let us recall British Airways and FILA UK cases) that occurred due to the activity of JS sniffers indicate that very few people know about this cyber threat and take measures to prevent infection.
XFSCashNCR	On September 19, Russia's Financial Sector Computer Emergency Response Team (FinCERT) issued an alert about the XFSCashNCR file, which is malicious software designed to steal money from NCR ATMs. Group-IB specialists searched for additional information on this file and established that it had not most likely been involved in any real attacks. Presumably, this file was created by Cyttek, a cyber security company, for PR purposes.

Deepfake

Criminals used deepfake software to impersonate a chief executive's voice and demand a fraudulent transfer of €220,000 to a Hungarian supplier. The CEO of a UK-based energy firm thought he was speaking on the phone with his boss, the chief executive of the firm's German parent company, and became suspicious when the fraudster called a third time requesting a second transfer and noticed the call was from an Austrian number. By that moment, the first transfer had gone to a Hungarian account under the scammers' control and had been then transferred to Mexico. This case became known thanks to the insurance company Euler Hermes Group, which was engaged in the incident investigation. The insurer believes the scammer had used commercially available AI voice-generating software to carry out the fraud.

Fake videos can also be created by editing or overlaying the faces of famous people who supposedly pronounce the necessary text and play the necessary role in the plot. For this, in particular, deepfake, a technology based on Deep Learning, can be used. It allows criminals to replace mouth movements and the person's speech in the video, which creates realistic imitations.

Arrests and sentences

Erratic

A former Amazon Web Services Inc. employee Paige A. Thompson a/k/a erratic, was charged with wire fraud and computer fraud and abuse for the intrusion into data of Capital One and more than 30 other entities. In June 2019, it was reported about the compromise of the American bank Capital One and the leak of data from 106 million users. Data of users that turned to the bank for credit cards in the period from 2005 to 2019 leaked to the side. That data included names, addresses, zip codes, phone numbers, email addresses, dates of birth and user income data. The leak also affected information on credit cards of bank's customers, such as data on credit ratings and limits, balances, payment history, as well as contact information and fragments of transactions for 23 days in 2016, 2017 and 2018. In addition, it was reported that the cracker gained access to a million Canadian Social Security numbers, more than 140,000 US Social Security numbers, and 80,000 bank account numbers.

Glubz, psycho

U.S. authorities have indicted two suspects for hacking cryptocurrency exchange EtherDelta in December 2017. One of the two suspects is Elliott Gunton, aka Glubz, a 20-year-old from the UK, better known for participating in the TalkTalk hack. The other is Anthony Tyler Nashatka, aka psycho, a resident of New York. Two years ago, scammers changed the site's DNS settings, and redirected traffic to a clone where they logged user credentials and then stole customer funds. Interestingly, the attack started with purchasing the personal details of an EtherDelta employee. The data, believed to have been acquired from underground data traders, contained the employee's phone number and email address. This person is believed to be Zachary Coburn, the company's CEO.

Forecasts and warnings

- New campaigns of the Android Trojan FANTA targeting customers of international banks can affect users of popular online resources AliExpress, Yula, Pandao, Aviasales, Booking, Trivago, and carsharing services and taxis.
- All the information about connections between Russian-speaking groups was first collected in one place, which can be very useful for cyber security specialists to attribute attacks.
- To avoid becoming a victim of JS sniffers, e-commerce website administrators need to regularly update software and engage independent experts for audit.
- Emporium Rodrigues, a supermarket chain in Brazil, has faced a threat of compromise. Attackers are known to have gained access to all POS terminals of stores, which poses is a risk of bank card data breach.

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organisation.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com